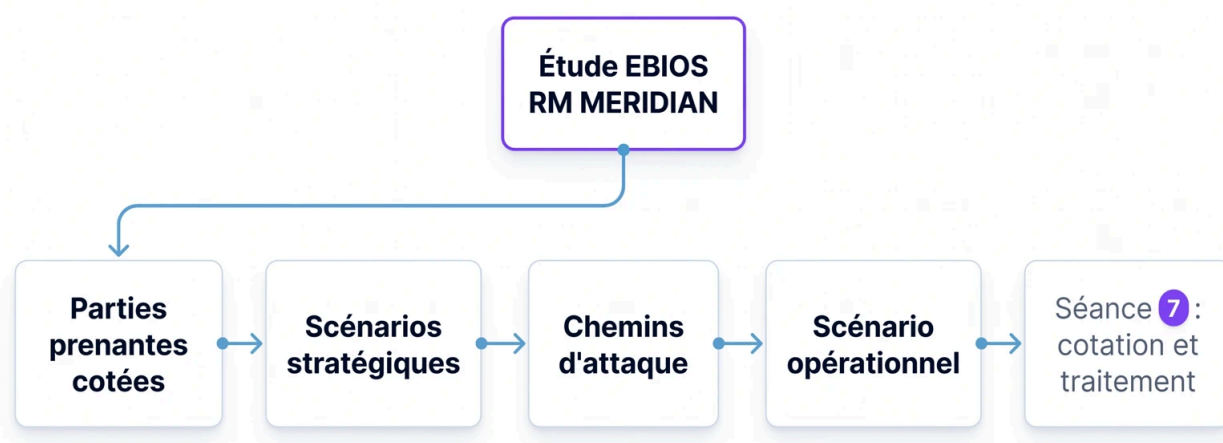


Analyse de l'écosystème et scénarios sur CISO Assistant

✓ Objectif : l'atelier 3 et l'amorce de l'atelier 4, dans l'outil



Objectifs de la séance

À l'issue de ce TP :

- **Compléter** l'étude EBIOS RM du groupe MERIDIAN avec son écosystème, saisi comme parties prenantes dans CISO Assistant
- **Coter** la dangerosité de chaque partie prenante sur les critères de l'outil et lire la criticité qu'il calcule
- **Créer** au moins deux scénarios stratégiques rattachés aux couples source de risque / objectif visé retenus, avec leurs chemins d'attaque

- **Amorcer** l'atelier 4 en déclinant un chemin d'attaque en scénario opérationnel coté en vraisemblance

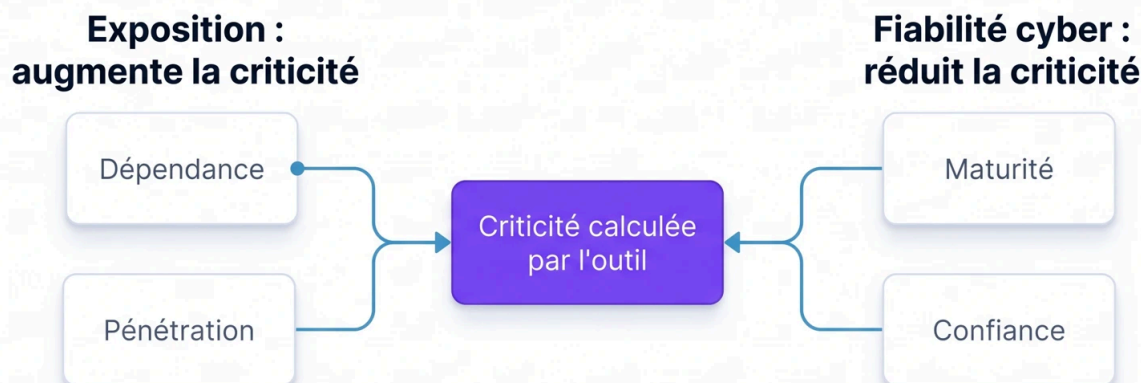
Prérequis

- Le domaine de la filiale instruite et les actifs saisis dans CISO Assistant depuis la séance 2 : les valeurs métier et les biens supports, à réutiliser sans jamais les recréer.
- Le travail de la séance 5 dans l'outil : la matrice « Matrice 4x4 EBIOS-RM » importée, et l'étude « Étude EBIOS RM MERIDIAN - [filiale instruite] et [dépendance du S6] - cycle 1 », crochets remplis en séance 5, avec ses ateliers 1 et 2 saisis : cadre, actifs reliés, audit du socle, six événements redoutés cotés, cinq couples SR/OV (source de risque / objectif visé) dont trois retenus.
- Le dossier D5 : le cadrage, les couples source de risque / objectif visé motivés, les événements redoutés cotés en gravité, et les échelles du groupe, à réutiliser telles quelles.
- Le TD de ce matin : la cartographie de dangerosité, les parties prenantes critiques, la structure d'un scénario stratégique et d'un scénario opérationnel.

Ce que ce TP manipule, et ce que l'outil sait faire

Ce TP prolonge dans l'outil le travail fait à la main ce matin, dans le module EBIOS RM ouvert hier. Hier, l'étude a été créée et ses ateliers 1 et 2 saisis : cadre, actifs, socle, événements redoutés, couples SR/OV. Aujourd'hui s'ouvrent les ateliers 3 et 4 de la même étude, ceux qui portent les parties prenantes cotées, les scénarios stratégiques, les chemins d'attaque et les scénarios opérationnels. Ce TP reprend cette étude, sans rien recopier, et y ajoute trois familles d'objets : les parties prenantes de l'écosystème, les scénarios stratégiques et leurs chemins d'attaque, puis un premier scénario opérationnel.

Deux points sur ce que l'outil fait, vérifiés sur la version déployée. D'abord, il modélise la partie prenante avec quatre critères de cotation, en valeur courante et en valeur résiduelle : la dépendance et la pénétration (qui mesurent l'exposition), la maturité et la confiance (qui mesurent la fiabilité cyber). Ensuite, il calcule lui-même la criticité de chaque partie prenante à partir de ces quatre notes, selon la logique du guide : l'exposition augmente la criticité, la fiabilité la réduit. Le résultat s'affiche comme un nombre, dépendance multipliée par pénétration, divisé par maturité multipliée par confiance, chaque note allant de 0 à 4. La dangerosité n'est donc pas à calculer soi-même : elle se justifie par les quatre cotations, et le résultat se lit. C'est exactement la cartographie de dangerosité de l'atelier 3, sous forme d'objets manipulables.



Ce TP est écrit en résultats à atteindre et en critères de validation, pas en suite de clics : à la fin, l'étude doit contenir tel objet, et c'est cela qui se vérifie à l'écran, quel que soit le chemin d'interface emprunté.

Un mot sur l'intérêt de saisir tout cela dans l'outil plutôt que sur une feuille. Un tableur d'écosystème vit trois semaines puis meurt dans un dossier partagé. Une étude EBIOS RM saisie dans l'outil, au contraire, relie chaque partie prenante à ses cotations, chaque scénario stratégique à son couple source de risque / objectif visé et à son événement redouté, chaque scénario opérationnel à son chemin d'attaque. Ces liens sont ce qui rend le travail transmissible : la séance 7 ne repartira pas de zéro, elle ouvrira l'étude et reprendra ses objets pour les coter et les traiter. Ce travail ne remplit pas un exercice, il construit une pièce du dossier MERIDIAN qui suivra le groupe jusqu'à la soutenance.

✓ Exercice 1 : reprendre l'étude EBIOS RM de la séance 5 (5 minutes)

Ouvrir l'étude créée en séance 5, « Étude EBIOS RM MERIDIAN - [filiale instruite] et [dépendance du \$6] - cycle 1 », et vérifier que ses ateliers 1 et 2 reflètent le D5, sans rien ressaisir : le D5 fait foi. Compléter dans l'étude tout objet manquant ou divergent.

À produire : la page de l'étude dont les compteurs affichent les actifs de la filiale, un audit, six événements redoutés et cinq couples SR/OV dont trois retenus, identiques au D5.

✓ Exercice 2 : saisir l'écosystème comme parties prenantes (10 minutes)

Reprendre l'objet d'étude du TD, l'actif critique n°1 de la filiale instruite, et identifier son écosystème à partir de la cartographie de la séance 2 et des §3 et §6 du dossier de filiale : au moins quatre parties prenantes, prises parmi les prestataires, les autres filiales et les clients qui y figurent. Créer chacune dans le module EBIOS RM et lui renseigner une catégorie parmi celles de l'outil.

À produire : au moins quatre parties prenantes rattachées à l'étude, chacune correspondant à un acteur nommé au §3 ou au §6, aucune inventée.

✓ Exercice 3 : coter la dangerosité et lire la criticité (15 minutes)

Pour chaque partie prenante, renseigner les quatre critères de cotation courante, dépendance, pénétration, maturité et confiance, en appuyant chaque note sur un fait du dossier de filiale et non sur une impression. Lire la criticité que l'outil calcule, repérer la ou les parties prenantes les plus critiques et cocher « Retenu » sur chacune : ce sont celles qui entreront dans les scénarios stratégiques.

À produire : au moins quatre parties prenantes cotées, chaque note justifiée par une ligne appuyée sur un fait du dossier, la criticité lue pour chacune, et les parties prenantes critiques cochées « Retenu ».

💡 La criticité de l'outil n'est pas une vérité tombée du ciel : c'est le produit des quatre notes saisies. Si le résultat surprend, ce ne sont pas les mathématiques qu'il faut contester, ce sont les cotations qu'il faut réexaminer et rejustifier. C'est le même réflexe qu'avec une grille pondérée en séance 3 : l'outil rend la délibération transparente, il ne délibère à la place de personne.

✓ Exercice 4 : créer deux scénarios stratégiques et leurs chemins d'attaque (15 minutes)

Prendre deux des trois couples SR/OV retenus à l'atelier 2 et, pour chacun, créer un scénario stratégique rattaché au couple et à l'événement redouté visé. Y créer au moins un chemin d'attaque passant par une partie prenante critique de l'exercice précédent, rattacher cette partie prenante et cocher « Retenu » sur le chemin. Décrire chaque

chemin en distinguant l'événement intermédiaire, porté sur l'écosystème, et l'événement redouté, porté sur la valeur métier ; lire la gravité sur l'échelle du D5.

À produire : deux scénarios stratégiques, chacun avec un chemin d'attaque coché « Retenu » relié à une partie prenante critique, gravité affichée depuis l'événement redouté.

✓ Exercice 5 : amorcer l'atelier 4 avec un scénario opérationnel (10 minutes)

Choisir le chemin d'attaque le plus préoccupant et créer le scénario opérationnel qui lui correspond : décrire l'enchaînement des actions élémentaires sur les biens supports, estimer sa vraisemblance globale sur l'échelle du D5 (V1 à V4) et le rattacher à son chemin d'attaque, coché « Retenu ». L'atelier 4 complet est la matière de la séance 7 ; ici, la première pierre.

À produire : au moins un scénario opérationnel rattaché à un chemin d'attaque, avec sa description de modes opératoires et sa vraisemblance justifiée par le socle de sécurité et ses limites.



Corrigés et critères d'évaluation – cliquer pour révéler